

Taller AAA resuelto

Diseño de un esquema de control de acceso para MediTech Solutions

Fundamentos de Seguridad de la Información. Escuela Colombiana de Ingeniería. Estudiante: Jose Luis Lancheros Ayora

Método de análisis

Para resolver el taller seguí el método de diseño de un esquema de control de acceso de la presentación de clase, que tiene seis pasos: identificar los usuarios, definir los recursos y activos, establecer roles y permisos, implementar autenticación segura, aplicar políticas de autorización y registrar las actividades mediante auditoría. En MediTech los usuarios son médicos, administrativos, pacientes y auditores externos, y los activos son las historias clínicas, la facturación y nómina, los logs y la agenda. La Fase A corresponde a la autenticación, la Fase B a los roles, permisos y autorización, y la Fase C a la auditoría. En cada decisión explico el riesgo que atiende y su limitación, porque ningún control elimina el riesgo por completo, solo lo reduce.

Fase A: Autenticación robusta

A.1 MFA para administrativos

Propongo una contraseña robusta como algo que el usuario sabe y un código temporal generado por una aplicación autenticadora instalada en su celular personal, como algo que tiene. Son dos factores de tipos distintos, que es lo que define una autenticación multifactor, MFA. Es económica porque no exige comprar hardware: la contraseña la recuerda cada persona y la aplicación es gratuita. Es efectiva porque, aunque un atacante robe la contraseña por phishing o fuerza bruta, que son riesgos señalados en la presentación, no tiene el celular y por tanto no puede entrar. Prefiero la aplicación al código por SMS porque el SMS puede interceptarse o desviarse con una clonación de SIM, así que lo dejo solo como respaldo. Descarto el correo como segundo factor porque se accede con otra contraseña, es decir, seguiría siendo algo que se sabe, y si el atacante ya robó una clave probablemente también robó la otra.

Este nivel es proporcional al riesgo del rol: los administrativos manejan agenda y cobros básicos, no ven diagnósticos y su acceso está limitado por mínimo privilegio. Aun así son blanco habitual de phishing, por eso no basta con la contraseña sola.

A.2 MFA para médicos con acceso a historias clínicas

Para los médicos propongo una contraseña robusta como algo que sabe y reconocimiento facial desde la cámara del celular personal como algo que es, con detección de vida para comprobar que hay una persona real y no una foto o un video. La biometría es crítica porque las historias clínicas tienen nivel de confidencialidad Muy Alto, y una filtración dañaría a los pacientes y a la organización. A diferencia de una clave, la biometría no se adivina ni se presta a un colega apurado. Además deja trazabilidad individual: el registro de auditoría prueba qué persona abrió la historia y el médico no puede alegar que fue otro con su clave, lo que se conoce como no repudio.

Reconozco limitaciones. El reconocimiento facial puede engañarse sin detección de vida, y en quirófano el tapabocas puede dificultarlo, por lo que se necesita una alternativa, como la huella en el dispositivo cuando no se usan guantes o la verificación del jefe de turno. La plantilla biométrica es un dato sensible que no se puede cambiar si se filtra, así que debe quedar cifrada en el dispositivo del médico y no en un servidor central. Por último, la autenticación solo confirma quién es la persona. Qué historias puede ver lo decide la autorización. Esta medida reduce el riesgo de suplantación, no lo elimina.

A.3 Gestión de fallos

Política de bloqueo. Permito tres intentos fallidos. Un número menor bloquearía al médico legítimo por un solo error de digitación, lo cual es grave en una emergencia, y un número alto le da al atacante muchas oportunidades de adivinar la clave. Tras los tres fallos aplico un bloqueo temporal progresivo, por ejemplo cinco minutos, luego treinta, y el contador no se reinicia cada día, para frenar ataques lentos que prueban pocas claves diarias. Descarto el bloqueo permanente porque dejaría a un médico fuera durante una atención. También advierto que un atacante podría bloquear a propósito a un médico fallando a propósito, por eso los intentos fallidos repetidos generan alerta al SIEM.

Recuperación. Para la contraseña, el médico usa un código temporal de una aplicación autenticadora, y la regla es que la recuperación nunca sea más débil que el inicio de sesión normal, para que robar el celular no sirva como atajo. Si falla la biometría por la cámara o el dispositivo, el médico se identifica ante el jefe de turno o la mesa de ayuda, que verifica su identidad y deja constancia. No guardo el rostro en una base central para usarlo en otros equipos, porque aumentaría el riesgo de un dato que no se puede cambiar.

Emergencias. Para que ninguna emergencia espere, existe un acceso de emergencia, conocido como break-glass: con la autorización de un supervisor o un colega, el médico recibe un acceso temporal y de alcance limitado a la historia necesaria. Para que no se convierta en una puerta trasera, toda utilización de break-glass queda registrada, dispara una alerta en el SIEM y se revisa después. Con esto equilibrio la confidencialidad con la disponibilidad.

Fase B: Autorización y matriz de control de acceso

Apliqué RBAC, donde los permisos se asignan a roles y cada persona recibe los de su rol. La matriz sigue el mínimo privilegio: cada permiso corresponde a una tarea real del rol. Convenciones: L leer, E escribir o editar, B borrar, N ningún acceso.

Recurso / Rol	Médicos	Administrativos	Pacientes	Audidores
Historias clínicas	L, E (solo sus pacientes)	N	L (solo la propia)	N
Facturación / Pagos	N	L, E (solo cobros)	L (solo lo propio)	N
Logs de seguridad	N	N	N	L
Agenda de citas	L, E (su disponibilidad)	L, E (sin borrar)	L, E (solo lo propio)	N

Historias clínicas. Los médicos leen y editan solo las de sus pacientes, porque necesitan los datos para diagnosticar. Los pacientes leen únicamente la propia, ya que el taller dice que consultan sus resultados por web o móvil. Los administrativos y los auditores tienen N para proteger la privacidad: la logística no requiere diagnósticos, y la auditoría verifica cumplimiento de seguridad, no contenido clínico. RBAC por sí solo no distingue la historia propia de la ajena, así que esas restricciones de solo lo propio se aplican con una regla adicional basada en atributos, como en ABAC. Nadie borra historias, porque son evidencia clínica y legal que debe conservarse.

Facturación y pagos. Los médicos tienen N porque no cumplen funciones de cobro. Los administrativos leen y editan solo lo relacionado con cobros, no la nómina ni los datos completos de tarjeta. Los pacientes leen solo sus facturas. Los auditores no necesitan ver salarios ni números de tarjeta, y si se requiriera auditar pagos se haría sobre datos enmascarados. Nadie borra, para conservar la trazabilidad.

Logs de seguridad. Solo los auditores leen. Nadie escribe ni borra manualmente, porque los logs son inmutables. Es segregación de funciones: quien genera la actividad no puede alterar la evidencia, y quien la revisa no puede modificarla.

Agenda de citas. Los médicos ven su agenda y editan su disponibilidad. Los administrativos gestionan la logística y modifican citas, pero cancelar es una edición que deja historial y no un borrado que elimine el rastro. Los pacientes ven y gestionan sus propias citas. Los auditores tienen N porque la agenda revela qué paciente va con qué especialista, lo cual insinúa condiciones de salud, y su tarea no lo requiere.

Pregunta de diseño: mínimo privilegio con el administrativo

Aplico el principio de mínimo privilegio dando al administrativo solo lo que necesita para su tarea, que es la logística de las citas. Sobre la historia clínica tiene N. En la agenda ve fecha, hora, paciente y médico, mediante una vista restringida. El motivo de la consulta y el diagnóstico no forman parte de la agenda, solo viven en la historia clínica, así que no se pueden filtrar por ahí. Es mejor que el dato no exista en ese recurso a que exista y esté oculto. Reconozco que el nombre o la especialidad del médico puede insinuar el diagnóstico, por ejemplo un oncólogo. Lo mitigo mostrando solo el nombre, sin la especialidad como campo aparte, y registrando cada consulta de la agenda para detectar abusos o consultas masivas. Así se cumple la privacidad del paciente, aunque el riesgo se reduce y no desaparece.

Fase C: Accounting, auditoría y SIEM

C.1 Eventos críticos para alertar en tiempo real

Primero, múltiples intentos fallidos de autenticación sobre una cuenta o bloqueo de cuenta, porque indica fuerza bruta o un intento de dejar a un médico fuera. **Segundo**, uso del acceso de emergencia break-glass, porque es un control excepcional que podría abusarse y debe revisarse siempre. **Tercero**, acceso a historias clínicas fuera de horario o en volumen anormal, como un usuario abriendo muchas historias en poco tiempo, que sugiere robo de datos o curiosidad indebida. **Cuarto**, creación de cuentas o cambios de rol y de privilegios, porque la escalada de privilegios es una técnica típica del atacante. Además del ejemplo del taller, el intento de borrado o modificación de logs, que atenta contra la evidencia.

C.2 Escenario: un médico intenta entrar a facturación un domingo a las 2:00 AM

Quien bloquea la acción es la autorización, el segundo componente de AAA. El médico pudo autenticarse correctamente, es decir, el sistema sabe quién es, pero en la matriz RBAC su rol tiene N sobre facturación. Una regla basada en atributos, como el horario, refuerza la negativa. El accounting no bloquea, registra el intento, y el SIEM correlaciona el evento y genera la alerta para investigar.

Para que el registro sirva en una investigación legal debe contener: el identificador único del usuario y su rol; cómo se autenticó, es decir los factores usados; la fecha y hora exacta con zona horaria y relojes sincronizados; la dirección IP y el dispositivo de origen; el recurso al que intentó acceder y la acción pretendida; el resultado, en este caso denegado, junto con la regla que lo negó; y el identificador de la sesión. Además el registro debe ser inmutable, protegido contra alteración con firmas o hashes, almacenado con copias y con una retención definida, de modo que pueda aceptarse como evidencia y se mantenga la cadena de custodia.

Fase D: Análisis de modelos

Según la diapositiva 18, en DAC el propietario del recurso decide quién puede acceder, y en MAC el acceso se basa en niveles de seguridad definidos por el sistema. En un entorno médico MAC puede ser más seguro por varias razones. Con DAC, un médico dueño de una historia podría compartirla por decisión propia o por error, o ser engañado para hacerlo, y si su cuenta es robada el atacante hereda esa capacidad de repartir permisos. Con MAC el dato clasificado como Muy Alto solo lo ven quienes tienen la autorización correspondiente asignada por la organización, y ningún usuario puede cambiarla por su cuenta. Eso da una política uniforme, auditable y más fácil de justificar ante la normativa de protección de datos de salud.

La contrapartida es que MAC es más rígido y puede estorbar en situaciones imprevistas, como una emergencia. Por eso se complementa con un acceso de emergencia controlado y registrado. Lo de la rigidez y la contrapartida es razonamiento propio, no viene de la presentación.

Socialización y conclusión

Estrategia de MFA contra el robo de identidad médica

Mi estrategia combina varios factores según el riesgo. A los médicos, que acceden al activo más sensible, les exijo una contraseña robusta y reconocimiento facial con detección de vida, de modo que robar una clave no basta para suplantarlos. Si fallan, hay bloqueo temporal progresivo y recuperación mediante verificación humana, sin guardar rostros en una base central. En emergencias existe un acceso temporal controlado que se registra y se revisa. Todo esto genera alertas en el SIEM, y así la autenticación se complementa con autorización y auditoría.

Una situación donde el Accounting salvó a la empresa

Situación hipotética: un paciente demanda a MediTech afirmando que una persona de recepción consultó su diagnóstico y lo divulgó. El registro de accounting muestra que las consultas a esa historia las hizo únicamente el médico tratante, autenticado con MFA, en horario de atención, y que el administrativo nunca

accedió a ella y solo vio la agenda con fecha, hora y nombre. Con esa trazabilidad la empresa demuestra con evidencia íntegra quién accedió y cuándo, y puede desvirtuar la acusación. Sin esos registros inmutables sería la palabra de uno contra la del otro.